

Fase 2: Analisis de Vulnerabilidades detectadas.

Servicio ftp (puerto 21) – vsftpd 3.0.3

Presencia de **CVE-2021-30047** Y **CVE 2021-3618**

Estas vulnerabilidades pueden permitir ataques de denegación de servicios (DoS) o manipulación de datos.. Además el reporte anterior confirmo que permite acceso anónimo. Representando un riesgo de compromiso de integridad de archivos.

Servicio SSh (Puerto22) OpenSSH 9.2.p1

Presencia de **CVE-2024-6387** conocido como regreSSHion. La cual permite la toma total del control del servidor de forma remota.

Servicio HHTTP (Puerto 80) Apache 2.4.62

El servidor web aloja una versión de wordpress obsoleta con múltiples vectores de ataque para el secuestro de sesiones y ejecución de scripts maliciosos.

MariaDB (Puerto 3306) - Credenciales Débiles:

Hallazgo: Se detectaron usuarios con contraseñas por defecto o extremadamente cortas.

Riesgo: Permite el compromiso total de la información almacenada en WordPress y posible escalada de privilegios.

Puertos Innecesarios (Superficie de Ataque):

Hallazgo: Los puertos 25 (SMTP) y 631 (IPP) están abiertos innecesariamente.

Riesgo: Exponen servicios que no se utilizan, aumentando los puntos de entrada para un atacante.

Simulacion de la explotación.

Utilizando el exploit para **CVE-2024-6387**, un atacante podría enviar paquetes diseñados al puerto 22 para interrumpir el proceso de autenticación y obtener una shell de root

```

(kali㉿kali)-[~]
$ nc -vn 192.168.1.55 22
(UNKNOWN) [192.168.1.55] 22 (ssh) open
SSH-2.0-OpenSSH_9.2p1 Debian-2+deb12u3

(kali㉿kali)-[~]
$

```

Esta captura confirmam que el servidor es vulnerable a regrewSSHion.

Ahora simulamos que hacemos el regreSSHion y podria extraer las credenciales de la base de datos con el siguiente **comando**:

cat /var/www/html/wp-config.php | grep -E 'DB_USER|DB_PASSWORD'

```

valid_lft forever preferred_lft forever
debian@debian:~$ cat /var/www/html/wp-config.php | grep -E 'DB_USER|DB_PASSWORD'
define( 'DB_USER', 'wordpressuser' );
define( 'DB_PASSWORD', '123456' );
debian@debian:~$

```

Una vez obtenido las credenciales podemos accedes a mariadb y podremos ejecutar lo siguiente:

```

type help, or hit ctrl+? for help. type ? to clear the current
MariaDB [(none)]> SHOW DATABASES;
+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
| sys |
| wordpress |
+-----+
5 rows in set (0.003 sec)

MariaDB [(none)]>

```

```
MariaDB [(none)]> SELECT user, host FROM mysql.user;
```

```
+-----+-----+
| User          | Host          |
+-----+-----+
| mariadb.sys   | localhost     |
| mysql         | localhost     |
| root          | localhost     |
| user          | localhost     |
| wordpressuser | localhost     |
+-----+-----+
```

```
5 rows in set (0.001 sec)
```

```
MariaDB [(none)]> █
```

Medidas de Corrección Aplicadas

Para cerrar los vectores de ataque demostrados, se deben ejecutar y documentar estas acciones:

Vulnerabilidad	Acción de Mitigación	Comando Sugerido
SSH (regreSSHion)	Parchear y deshabilitar acceso Rot	<code>sudo apt install --only-upgrade openssh-server¹⁰.</code>
FTP Anónimo	Deshabilitar acceso anónimo en vsftpd.conf ¹¹ .	<code>sudo systemctl stop vsftpd</code>
Permisos Web	Restringir lectura de credenciales	<code>sudo chmod 600 /var/www/html/wp-config.php</code>
Puertos Innecesarios	Cerrar servicios de impresión y otros	<code>sudo systemctl stop cups</code>